

Lab 2: Creating Secure Architectures

Aim

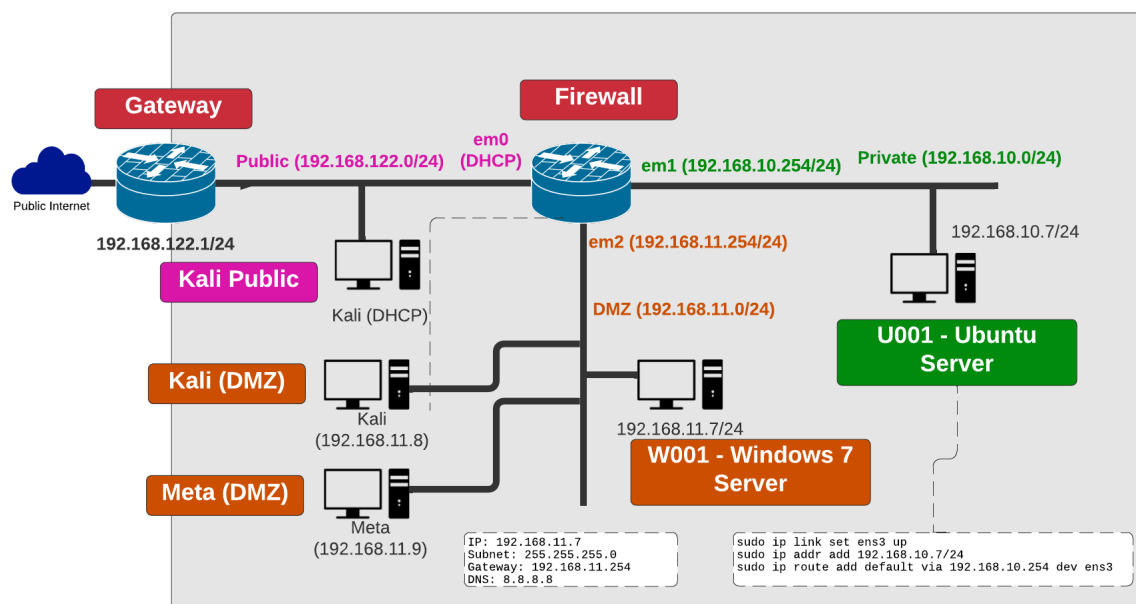
The aim of this lab is to build a secure architecture.

Activities

Complete Lab 2: The lab is here and there a demo of the lab here.

Lab setup

From Lab 1, we should now have this setup:



User logins:

- Ubuntu- User: user, Password: 1234
- Kali- User: napier, Password: napier123
- Windows- User: Administrator, Password: napier123
- pfsense- User: admin, Password: pfsense
- Metasploitable- User: msfadmin, Password: napier123

Key TCP ports:

- 21 FTP commands.
- 23 Telnet.
- 25 SMTP. Sending email.

- 53 DNS.
- 80 HTTP.
- 110 POP3. Receiving email.
- 443 HTTPs.

Firewall set up

On the firewall, from Diagnostics, view the ARP cache. Which addresses are in the cache?

On the firewall, from Diagnostics, ping each of the 192.168.10.254 and 192.168.10.7 interfaces from the LAN network. Can you ping them? [Yes/No]

On the Windows host, ping the 192.168.11.254 and 192.168.11.7 interfaces. Can you ping them? [Yes/No] Why can't you ping the 192.168.11.254 interface?

On the firewall, create a rule which allows a host on the DMZ to use ICMP to any destination.

On the Windows host, ping 192.168.11.254 and 192.168.11.7 interfaces. You should now be able to ping them.

On the Windows host, ping 192.168.10.254 and 192.168.10.7 interfaces. You should now be able to ping them.

On the firewall, create a rule which allows the Public network to ping both the DMZ and Private network. From the firewall, can you ping the hosts in the DMZ and Private network from the WAN port? The answer should be no, as the routing has not been set yet.

Now from the Windows host and the Ubuntu host, ping all the key addresses, including the gateway 192.168.122.1.

2.1 Metasploitable host

Now we will investigate the Metasploitable host.

Run NMAP from Windows to Metasploit. Which services are enabled:

```
[ftp][ssh][telnet][smtp][domain][http][vnc]
```

Run NMAP from Ubuntu to Metasploit. Which services are enabled:

```
[ftp][ssh][telnet][smtp][domain][http][vnc]
```

Now we will investigate the Metasploitable host for Telnet:

From Windows, run Wireshark and capture packets. Now log into Metasploitable using telnet:

```
telnet 192.168.11.9
```

Can you log into Metasploit with Telnet: [Yes/No]

Stop Wireshark and examine the data packets. Can you find the Telnet login session, and can you discover the password used? [Yes/No]

From Ubuntu, run Wireshark and capture packets. Now log into Metasploitable using telnet:

```
telnet 192.168.11.9
```

Can you log into Metasploit: [Yes/No]

Stop Wireshark and examine the data packets. Can you find the Telnet login session, and can you discover the password used? [Yes/No]

Note: login for Telnet in Metasploitable is User: msfadmin, Password: napier123

Now we will investigate the Metasploitable host for Telnet:

From Windows, run Wireshark and capture packets. Now log into Metasploitable using SSH:

```
ssh 192.168.11.9 -l msfadmin
```

Can you log into Metasploit: [Yes/No]

Stop Wireshark, and examine the data packets. Can you find the Telnet login, and can you discover the password used? [Yes/No]

From Ubuntu, run Wireshark and capture packets. Now log into Metasploitable using SSH:

```
ssh 192.168.11.9 -l msfadmin
```

Can you log into Metasploit: [Yes/No]

Stop Wireshark and examine the data packets. Can you find the SSH login session, and can you discover the password used? [Yes/No]

Note: in Wireshark, use tcp.port==23 as a filter for Telnet and use tcp.prt==22 as a filter for SSH.

Device Audit

Now we will make sure everything is in order with our infrastructure, such as for testing for network traffic, MAC addresses and so on. Audit list:

Perform and answer the following:

On the firewall, capture traffic on the DMZ port, and generate some traffic from the LAN to the DMZ (such as accessing the Web server in the DMZ). Does the traffic have the IP address of the gateway on the LAN port? Tick []

Perform and answer the following:

On the firewall, capture traffic on the WAN port, and generate some traffic from the LAN and DMZ (such as accessing Google.com). Does the traffic have the IP address of the WAN port? Tick []

On the firewall, examine the ARP table. Also on the hosts in the DMZ and the LAN, run arp -a, and determine all your MAC addresses. Do all the MAC addresses tie up? Tick []

NMAP

Run Wireshark on both hosts. Now run NMAP from the Linux host to the Windows host, and from the Windows host to the Linux host.

Perform and answer the following:

What IP addresses are used in the source addresses of the scan?

Which services have been identified from the Linux host to the Windows host?

Which services have been identified from the Windows host to the Linux host?

Why are these different in their scope? Where is the blocking happening?

Now enable http (Port 80), https (Port 443), and ftp (Port) from the Private network to the DMZ.

Perform and answer the following:

Re-do NMAP. How are the scans different?

Can you now access the Web server from the Linux host to the Windows host?

Can you now access the Web server from the Windows host to the Linux host?

Access Google.com from the Ubuntu host and also the Windows host.

Perform and answer the following:

Can you access it? If not, on the firewall, enable UDP/TCP DNS (Port 53) from DMZ and also from the Private network. Add logging on the rule.

Can you now access Google.com from the Linux host and the Windows host?

On the firewall, examine the log and view the accesses for a DNS lookup on Google.com. Which addresses are present?

Identifying Services

Within a network infrastructure, we have services which run on hosts. These services provide a given functionality, such as for sending/receiving email, file storage, and so on.

From → To	Command	Observation
DMZ	On your Windows host, run the command: netstat -a and outline some of the services which are running	Outline some of the services which are running on your

From → To	Command	Observation
	on your host (define the port number and the name of the service and only pick off the LISTENING status on the port).	host (define the port number and the name of the service):
LAN	For the Ubuntu Virtual Machine, and run the command: netstat -l.	Outline some of the services which are running on your host (define the port number and the name of the service):
DMZ	Next we will determine if these services are working. There should be a Web server working on each of the virtual machines (Ubuntu and Windows 2003), so from the Windows host and using a Web browser, access the home page: http://192.168.10.7	Is the service working: [Yes] [No]
LAN	From Ubuntu, access the Web server at: http://192.168.11.7	Is the service working: [Yes] [No]
LAN	Next we will determine if these services are working using a command line. From your UBUNTU host, undertake the following: telnet 192.168.11.7 80 then enter: GET /	Outline the message that is returned:
DMZ	Repeat the previous example from the WINDOWS host: telnet 192.168.10.7 80	
DMZ	There should be an FTP server working on Ubuntu and Windows 2003. From WINDOWS, access the FTP server on the UBUNTU server: "telnet 192.168.10.7 21" then enter: "USER user" then "PASS 1234" and then "QUIT"	Outline the messages that you received: What happens to each of these when you try with an incorrect username and password:
LAN	From UBUNTU access the WINDOWS host with "telnet 192.168.10.7 21" then enter: "USER Administrator" then "PASS napier" and then "QUIT"	Outline the messages that you received: What happens to each of these when you try with an incorrect username and password:
DMZ	On the UBUNTU instance, you will see that the VNC service is running, which is the remote access service. From your WINDOWS host, access the VNC service using a VNC client, and see what happens (you may have to open up Port 5900 to do so).	What does this service do:

Enumeration – Host scan

Nmap is one of the most popular network scanning tools. It is widely available for Windows and Linux/Unix platforms, and has both a Command Line Interface (CLI) and a Graphical User Interface (GUI).

From → To	Command	Observation
LAN to WAN	<code>sudo nmap -sP -r 10.221.0.0/24</code>	Which hosts are on-line:
LAN to DMZ	<code>sudo nmap -sP -r 192.168.11.0/24</code>	Which hosts are on-line:
DMZ to LAN	<code>nmap -sP -r 192.168.10.0/24</code>	Which hosts are on-line:
LAN to DMZ	Run Wireshark on host in LAN, and run: <code>sudo nmap -sP -r 192.168.11.0/24</code>	Which transport layer protocol does NMAP use to discover the host: [ICMP] or [ARP]
LAN to LAN	Run Wireshark on host in LAN, and run: <code>sudo nmap -sP -r 192.168.10.0/24</code>	Which transport layer protocol does NMAP use to discover the host: [ICMP] or [ARP]

Enumeration - Operating System Fingerprinting

Enumeration is the gathering of information about target hosts. After discovering live target systems, we want to identify which machines are running which OSs. A useful feature of nmap, is determining the operating system of hosts on the network. It performs active OS fingerprinting by sending packets to the target system.

From → To	Command	Observation
LAN to DMZ	Perform an OS Fingerprint Scan on some of the hosts discovered on the network, using a command such as: <code>sudo nmap -O 192.168.11.0/24</code>	Which operating systems does it return:
DMZ to LAN	Perform an OS Fingerprint Scan on some of the hosts discovered on the network, using a command such as: <code>nmap -O 192.168.10.0/24</code>	Which operating systems does it return:

Enumeration – Application Fingerprinting

Application Fingerprinting or Banner Grabbing covers techniques to enumerate OSs and Applications running on target hosts. An attacker or security tester would be specifically looking for versions of applications and operating systems which have vulnerabilities. Nmap can be used to check applications and versions for network services running on the target for the open ports it finds during a port scan.

From → To	Command	Observation
LAN to DMZ	Perform an application and version scan for networked services: <code>sudo nmap -sS 192.168.11.7/24</code>	Which services are running on the Windows host:

From → To	Command	Observation
DMZ to LAN Perform an application and version scan for networked services: nmap -sS 192.168.10.7/24	Which services are running on the Linux host:	
LAN to DMZ	Scan the Web server in the DMZ for its version: sudo nmap -sV 192.168.11.7/24 -p 80	Which Web server type is being used:
DMZ to LAN	Scan the Web server in the LAN for its version: nmap -sV 192.168.10.7/24 -p 80	Which Web server type is being used:

Telnet is another tool commonly used for banner grabbing. Once open ports have been found using a scanner, Telnet can be used to connect to a service and return its banner.

From → To	Command	Observation
DMZ to LAN	Connect to port 80, with: telnet 192.168.10.7 80 and then send the HTTP OPTIONS command to the web server: OPTIONS / HTTP/1.0	What is returned and how can this be used to fingerprint the web server? Which web server is running and which version?
DMZ to LAN	Similarly, other HTTP commands such as HEAD (get an HTML page header) and GET (get the whole HTML page) can be used to footprint a web server. Try the following and observe: HEAD / HTTP/1.0 and GET / HTTP/1.0	What do you observe from using these HTTP requests:

Brute Force

For this part of the lab, we will crack the username and password on the FTP login on Metasploitable. We will on Kali (DMZ), where you create a user file and password file with the following lists:

list_user:

- administrator
- admin
- root
- msfadmin
- guest

list_password:

- adminpass
- password
- Password
- 123456

- napier123
- pa\$\$word

Next, start Wireshark on Kali (DMZ), and then run Hydra with these usernames and passwords:

```
# hydra -L list_user -P list_password 192.168.11.9 ftp
```

From this, determine one of the usernames and passwords.

Stop Wireshark and find the Hydra trace. What do you observe from the trace:

What is the FTP status code for an incorrect login:

What is the FTP status code for a correct login:

Next, run Hydra and crack the username and the password for the Web server. With these usernames and passwords, we will target the DVWA site. First, access the Web server from:

```
http://192.168.11.9/dvwa/login.php
```

Next, start Wireshark on Kali (DMZ), and then run Hydra to try a range of logins:

```
# hydra -L list_user -P list_password 192.168.11.9 http-post-form
'/dvwa/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed'
```

From this, determine one of the usernames and passwords.

Stop Wireshark and find the Hydra trace. What do you observe from the trace:

What is the HTTP status code for an incorrect login:

What is the HTTP status code for a correct login:

Now access the Mutillidae site on Metasploit:

```
http://192.168.11.9/mutillidae
```

Now we will attack the Mutillidae site:

```
# hydra -L list_user -P list_password 192.168.11.9 http-post-form
'/mutillidae/index.php?page=login.php:username=^USER^&password=^PASS^&login
-php-submit-button=Login:Not Logged In'
```

From this, determine one of the usernames and passwords.

Metasploit Framework

The Metasploit Framework includes hundreds of auxiliary modules that perform scanning, fuzzing, sniffing, and much more. Although these modules will not give you a shell, they are

extremely valuable when conducting a penetration test. Generally, they are grouped in three categories: Admin, Scanner and Server.

Scanning

K.1 We can use Metasploit to perform a scan. First, we will search for the portscan module:

```
msf > search portscan
```

What do you observe from the run:

K.2 Start Wireshark. We can now perform a TCP port scan using Metasploit's auxiliary module:

```
msf > use auxiliary/scanner/portscan/tcp
msf auxiliary(tcp) > set RHOSTS 192.168.11.7
run
```

Which ports are open on the Windows 7 host?

From your Wireshark trace (using the filter in the form ip.addr==1.2.3.4), identify how Metasploit identifies an open port and a closed port.

K.3 We can now perform a SYN port scan and capture the traffic with Wireshark:

```
msf > use auxiliary/scanner/portscan/syn
msf auxiliary(syn) > show options
msf auxiliary(syn) > set RHOSTS 192.168.11.7
RHOSTS => 192.168.11.7
msf auxiliary(tcp) > run
```

What is the main difference between the TCP SYN scan and the TCP port scan?

K.4 Now we will discover the NetBIOS name of the Windows 7 (The "nbname" auxiliary module scans a range of hosts and determines their hostnames via NetBIOS).

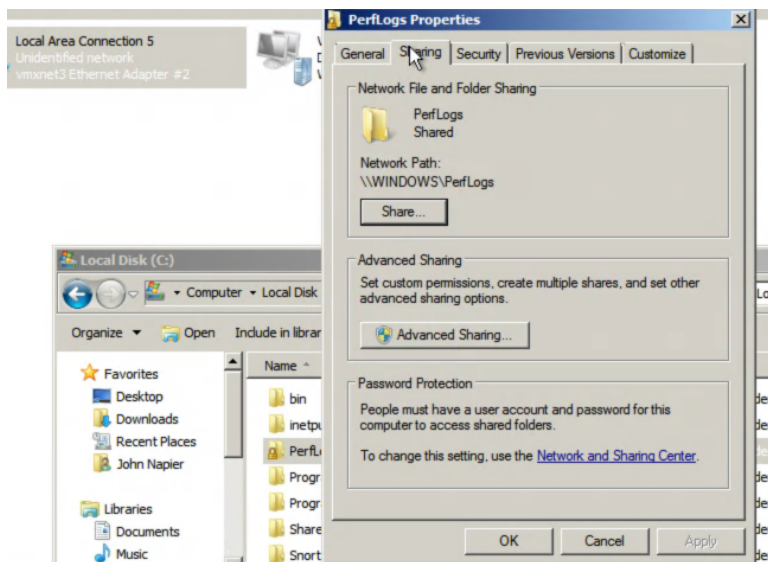
```
use auxiliary/scanner/netbios/nbname
```

What are the NETBIOS names on your network (scan the range for the DMZ)?

Server Message Block (SMB)

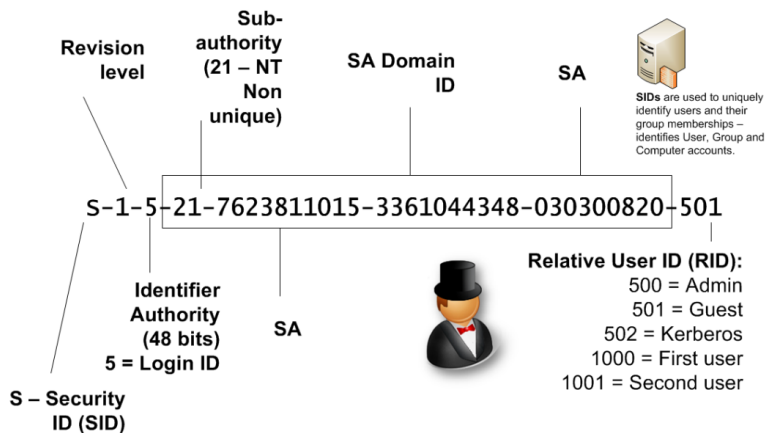
Microsoft Windows uses the Server Message Block (SMB) Protocol, one version of which was also known as Common Internet File System (CIFS), and operates as an application-layer network protocol mainly used for providing shared access to files, printers, and serial ports and miscellaneous communications between nodes on a network.

K.5 On Microsoft Windows 7, share the perlogs folder:



Every Microsoft host has an SID which uniquely identifies it, and where each user has a RID identifier:

```
C:> user2sid \pluto guest
S-1-5-21-7623811015-3361044348-030300820-501
C:> siduser 5 21 7623811015 3361044348 030300820 500
Name is Fred
Domain is PLUTO
```



K.6 Now go to Kali on your DMZ and start Wireshark. Next, run msfconsole, and set up the scan for the SMB share:

```
$ msfconsole
msf > use auxiliary/scanner/smb/smb_enumshares
msf auxiliary(smb_enumshares) > set RHOSTS 192.168.11.7
RHOSTS => 192.168.11.7
msf auxiliary(smb_enumshares) > set SMBUser napier
SMBUser => napier
msf auxiliary(smb_enumshares) > set SMBPass napier123
SMBPass => napier123
msf auxiliary(smb_enumshares) > run
```

K.7 As would be expected, smb_enumshares module enumerates any SMB shares that are available on a remote system.

What is the name of the folder they created?

From the Wireshark trace, which TCP port SMB uses to connect?

K.8 The smb_lookupsid module brute-forces SID lookups on a range of targets to determine what local users exist on the system:

```
$ msfconsole
msf > use auxiliary/scanner/smb/smb_lookupsid
msf auxiliary(smb_lookupsid) > show options
msf auxiliary(smb_lookupsid) > set RHOSTS 192.168.11.7
RHOSTS => 192.168.11.7
msf auxiliary(smb_lookupsid) > set SMBUser napier
SMBUser => napier
msf auxiliary(smb_lookupsid) > set SMBPass napier123
SMBPass => napier123
msf auxiliary(smb_lookupsid) > run
```

What is the SID of the Windows 7 computer?

Ask another group for their SID. For the Administrator account, is the SID different from yours?

What does an RID of 500 identify?

What is special about the RID values of 1,000 and above?

K.9 Metasploit's smb_login module will attempt to log in via SMB across a provided IP address (es). If you have a database plugin loaded, successful logins will be stored in it for future reference and usage.

```
msf > use auxiliary/scanner/smb/smb_login
msf auxiliary(smb_login) > set RHOSTS [W.X.Y.Z]
RHOSTS => [W.X.Y.Z]
msf auxiliary(smb_login) > set SMBUser [USER]
SMBUser => Administrator
msf auxiliary(smb_login) > set SMBPass [PASSWORD]
SMBPass => napier
msf auxiliary(smb_login) > run
```

Using the show options command in Metasploit, you can clearly see that this module has many more options than other auxiliary modules and is quite versatile. The smb_login module can also be passed a username and password list in order to attempt to brute-force login attempts across a range of machines.

K.10 Create a Username file (users.txt) and a Password file (passwords.txt) with all the following using "nano" command in Kali DMZ:

users.txt: Administrator, napier, root, Guest, test, default, [USER] passwords.txt: napier123, test, guest, password, changeme, [PASSWORD]

```
msf > use auxiliary/scanner/smb/smb_login
msf auxiliary(smb_login) > show options
Check if you can see PASS_FILE and USER_FILE
```

```
msf auxiliary(smb_login) > set PASS_FILE /home/napier/passwords.txt
set PASS_FILE /root/passwords.txt
msf auxiliary(smb_login) > set USER_FILE /home/napier/users.txt
set USER_FILE /root/users.txt
msf auxiliary(smb_login) > run
```

Which user names and passwords did it detect?
